

KudiPay Security Incident Report

Analyst: Security Operations Team

1. EXECUTIVE SUMMARY

This report presents a complete end-to-end reconstruction of a simulated cyberattack against KudiPay, based on network traffic analysis, SIEM logs, and penetration testing results.

The investigation confirms a **multi-stage intrusion** involving:

- Likely web application exploitation
- Internal network access
- Lateral movement using Remote Desktop Protocol (RDP)
- Suspicious DNS communication linked to possible command-and-control behavior
- Outbound RDP session from internal host to external IP

No system downtime was recorded. However, the attacker achieved **unauthorized internal access and maintained active control over systems**, representing a significant security incident.

Key Risk Summary:

- Confidentiality: HIGH IMPACT
- Integrity: MEDIUM IMPACT
- Availability: NO IMPACT

Core Finding:

The breach could have been prevented at a single low-cost control point:
Outbound traffic restriction (especially RDP and DNS filtering).

2. INCIDENT OVERVIEW

The attack began with subtle network activity that initially appeared legitimate.

A DNS request was observed for:

data-sync.exfil-node.net → 193.27.14.88

This was followed by internal Remote Desktop Protocol (RDP) sessions and later an external RDP connection from inside the network.

Key activity:

- Internal host communication using RDP (port 3389)
- Access to internal dashboard via HTTP
- External RDP session detected
- Active data transfer confirmed (29,825 bytes)

These behaviors indicate that the attacker had already established a foothold before detection.

3. TIMELINE OF EVENTS

Phase	Event
Initial Access	Web application likely exploited
Entry	Injection-based vulnerability (DVWA-like login page)
Reconnaissance	Internal systems discovered
DNS Activity	Query to suspicious domain
Lateral Movement	RDP between internal hosts
Internal Access	HTTP dashboard interaction
External Activity	Outbound RDP session
Detection	SIEM alert triggered

The attack progressed quietly through trusted protocols, avoiding early detection.

4. INITIAL ACCESS (ENTRY POINT)

Penetration testing on the mirrored environment suggests the most likely entry vector was a **web application vulnerability (OWASP A03: Injection)**.

Observations:

- Publicly accessible HTTP login page
- Lack of strong input validation
- No enforced WAF protections

Likely Attack Method:

- Input manipulation or SQL injection
- Authentication bypass or session hijack
- Initial foothold inside internal network

Outcome:

Attacker gained access without triggering immediate alerts.

5. INTERNAL MOVEMENT & DNS ACTIVITY

After initial access, the attacker moved internally using legitimate protocols.

Internal Lateral Movement:

- 10.10.2.50 → 10.10.5.23 via RDP
- TPKT traffic confirmed active RDP session

DNS Indicator:

- **data-sync.exfil-node.net**
- Resolved to **193.27.14.88**

Interpretation:

- Possible command-and-control (C2) channel
- Potential staging point for external communication
- Early indicator of exfiltration preparation

The attacker blended into normal traffic using trusted services.

6. EXTERNAL COMMUNICATION & RDP ABUSE

A critical outbound connection was detected:

- Source: 10.10.5.31
- Destination: 142.250.0.14
- Protocol: TCP 3389 (RDP)
- Bytes transferred: 29,825

Significance:

Outbound RDP is highly unusual in enterprise environments.

Implications:

- Active remote session confirmed
- Possible attacker-controlled tunnel
- External pivot or persistence channel

This was classified as a **TRUE POSITIVE alert** by SOC.

7. SECURITY LAYER BREAKDOWN

Layer	Observed	Missed
Application	Login traffic normal	Injection attempts
Network	DNS + RDP visible	Suspicious domains ignored
Endpoint	RDP sessions active	Unauthorized usage missed

SOC

Outbound RDP
detected

Late detection

Key Insight:

Each layer individually appeared normal. The breach only became visible when events were correlated.

8. IMPACT ASSESSMENT

Confidentiality (HIGH)

- Suspicious external communication
- Likely exposure risk of internal data

Integrity (MEDIUM)

- Unauthorized RDP access enables modification of systems
- Possible manipulation of internal data or dashboards

Availability (LOW)

- No outages or service disruption observed

Business Risk:

- Potential exposure of sensitive financial data
 - Regulatory reporting risk under data protection laws
 - Loss of customer trust if data exposure confirmed
-

9. ROOT CAUSE & PREVENTION POINT

Root Cause:

- Weak web application security controls
- Lack of outbound traffic restrictions
- Insufficient monitoring of RDP activity

- Poor network segmentation

Most Critical Prevention Layer:

Egress Filtering (Outbound Traffic Control)

Why this matters:

Blocking outbound traffic would have:

- Prevented external RDP session
- Blocked communication with suspicious domain
- Cut off attacker control channel
- Contained attacker inside network

This is the **lowest-cost, highest-impact control failure** in the entire incident.

10. REMEDIATION & CONCLUSION

Immediate Actions

- Isolate affected systems (10.10.5.31, 10.10.5.23)
- Block outbound TCP 3389
- Reset compromised credentials
- Investigate authentication logs

Short-Term Improvements

- Deploy Web Application Firewall (WAF)
- Improve SIEM correlation rules for RDP/DNS
- Enable DNS anomaly detection
- Strengthen endpoint monitoring

Long-Term Security Strategy

- Implement Zero Trust architecture
- Enforce MFA for all remote access
- Segment internal network properly
- Conduct continuous penetration testing

- Strengthen logging and visibility across all layers
-

Final Conclusion

The KudiPay breach demonstrates a modern attack chain where no single control failure caused the incident. Instead, attackers exploited multiple small weaknesses across different layers.

The most important lesson is that **visibility without enforcement is not security**.

A single missing control — outbound traffic restriction — allowed the attacker to move freely, communicate externally, and maintain access.

Technical Appendix (Condensed)

Firewall Log

```
fw=KUDI-FW01 action=ALLOW proto=TCP  
src=10.10.5.31 dst=142.250.0.14 dport=3389 bytes=29825
```

DNS Record

```
data-sync.exfil-node.net → 193.27.14.88
```

Commands Used

```
grep "dport=3389" firewall_syslog.log  
awk '/dport=3389/ {print $1, $5, $7, $9, $11}' firewall_syslog.log
```

My report is supported by ChatGPT